IA5 Secure Data Exchange Build

Student: Laurence Matthew B Manuel **Section:** BSIT 3A **Project:** Project 29 Thesis Consultation Reminder System
Milestone: Week 14 v2.0.0 **Executed:** 8 November 2026 Asia/Manila

Build result

The existing Flutter Web and Laravel application now performs an end-to-end controlled sender/receiver exchange. A signed-in coordinator selects a consultation and receives an AES-256-GCM envelope. The envelope contains authenticated metadata and ciphertext but no key. A signed-in assigned adviser pastes it into the receiver view. Laravel verifies encoding, timestamps, sender, GCM tag, role, recipient, consultation assignment and replay status before returning the minimized plaintext. Reusing the accepted envelope produces a visible HTTP 409 error with a correlation reference.

Implementation map

Layer	Week 14 implementation
Flutter	HTTPS API default, coordinator create action, ciphertext display, adviser JSON receiver, safe invalid/network/auth/replay feedback, responsive cards and labeled fields
API routes	Rate-limited `POST /api/secure-exchange/envelopes` and `POST /api/secure-exchange/receive` under session middleware
Authentication	Opaque random bearer session; hashed database token; two-hour expiry; logout; login throttle
Authorization	Coordinator-only creation; adviser-only receipt; exact recipient and assigned-consultation checks
Cryptography	PHP OpenSSL AES-256-GCM, 32-byte key, random 12-byte nonce, 16-byte tag, canonical additional authenticated data
Freshness/replay	UUID message ID, authenticated issue/expiry times, five-minute TTL, 30-second future skew, unique receipt table
Configuration	Ignored server keyring, blank `.env.example`, provisioning/rotation command, separate ignored TLS keys
Transport	Short-lived localhost CA/certificate, TLS 1.2 minimum gateway, HTTPS-only Flutter build, strict CORS origin
Logging	Correlation IDs and allowlisted event metadata; no password, token, key, ciphertext, agenda or request body
Data minimization	Six consultation fields only; no names, emails, action text, automation history or audit data in envelope

Normal execution

At 20:37:07+08:00, the scripted HTTPS path created and accepted an authenticated envelope for fictional consultation 4. The API returned HTTP 200 and `Secure consultation record accepted.` Browser evidence independently shows the assigned adviser view returning consultation ID, fictional agenda, status, Manila schedule and open-action count. One replay receipt was created.

Adverse and recovery results

Case	Prediction	Actual safe behavior	Evidence
Replay	Conflict and no second receipt	HTTP 409 `Envelope was already accepted.`; browser shows correlation reference	SEC-HTTP-02, APP-04
Altered ciphertext	Tag verification failure; no plaintext/receipt	HTTP 422 `Envelope authentication failed.`	SEC-HTTP-03, feature test
Altered recipient metadata	Tag verification failure before	HTTP 422; no receipt	feature test

Case	Prediction	Actual safe behavior	Evidence
	authorization		
Expired authentic envelope	Reject validity window	HTTP 422; no receipt	clock-controlled feature test
Invalid empty envelope	Validation failure	HTTP 422 with required-field errors	SEC-HTTP-05
Unauthorized panel/other adviser	No plaintext	HTTP 403	SEC-HTTP-04, feature test
Wrong key	Authentication failure	HTTP 422; no receipt	feature test
Missing keyring key	Safe unavailable response	Generic HTTP 503; after restoring test key, create/receive succeeds	feature test
Missing TLS trust anchor	Connection must fail	Certificate rejected as unknown issuer	SEC-TLS-02
CORS gateway defect	Browser blocks request and does not downgrade	Safe visible network error; allowlist fixed; successful browser rerun	Activity 2 record
Login burst	Bounded rate limit	HTTP 429 `Too Many Attempts`; cache cleared only in controlled lab before rerun	browser observation

Repeatable commands

From the repository root:

```
Set-Location 'C:\Users\Laure\Documents\ChatGPT\IPT\backend'
& 'C:\xampp\php\php.exe' artisan test

Set-Location 'C:\Users\Laure\Documents\ChatGPT\IPT\frontend'
& 'E:\Flutter\flutter_windows_3.47.8-stable\flutter\bin\flutter.bat' analyze
& 'E:\Flutter\flutter_windows_3.47.8-stable\flutter\bin\flutter.bat' test
& 'E:\Flutter\flutter_windows_3.47.8-stable\flutter\bin\flutter.bat' build web --release --dart-
define=API_URL=https://localhost:8443/api

Set-Location 'C:\Users\Laure\Documents\ChatGPT\IPT'
& '.\submissions\week-14\tests\Invoke-Week14Security.ps1'
```

Run the TLS verification with the bundled workspace Python path documented in `logs/environment.txt`. Do not print the keyring or use a certificate-warning bypass.

Limitations and maintenance

The HTTPS gateway and CA are local assessment controls, not a deployment package. The loopback gateway-to-Laravel hop is HTTP. The AES key is protected by local file/account access rather than an HSM or KMS. Shared-key authentication does not provide nonrepudiation. MariaDB at-rest encryption, centralized monitoring, multi-factor authentication, distributed replay storage, external notification providers, certificate revocation infrastructure and production incident response are outside Week 14.

Maintain the system by keeping framework/runtime dependencies reviewed, rotating the AES key and certificate, removing the previous key after the five-minute grace period, checking time synchronization, pruning replay receipts only under an approved retention rule, reviewing security logs by correlation ID, rerunning all adverse tests after configuration changes, and removing the local CA from trust when the exercise is complete.

Evidence-supported conclusion

The build meets the bounded Week 14 sender/receiver exercise: it uses an established AEAD library, keeps keys outside Flutter and source, uses HTTPS, enforces authentication and role/assignment authorization, validates both client/server boundaries, minimizes data, logs safely, rejects required adverse cases, and preserves recovery evidence. The claim is limited to the recorded controlled environment and source revision `03d9ed3`, which extends `v1.0.0`.

Acknowledgment

The build uses Laravel, Flutter, PHP OpenSSL, Python cryptography and standard TLS libraries. AI assistance supported implementation, testing, evidence capture and report drafting. Exact institutional acknowledgment wording remains subject to instructor guidance.